Microfinance and Susu Management System

Internal Technical Blueprint

Architecture, controls, delivery plan and implementation decisions

Document control	Value
Audience	Stormglide delivery team, client technical sponsor, finance lead, compliance lead and operations leadership
Status	Internal planning blueprint - implementation is not authorized by this document alone
Version	1.0 | 27 September 2026
Source basis	Microfinance and Susu Management System Project Blueprint (24 pages) plus the recorded KYC and fallback decisions
Primary outcome	A build-ready, controlled architecture for a cash-recording financial operating system, beginning with Susu

Prepared for internal technical planning. All regulatory statements are design assumptions to validate with the client, their legal counsel, Bank of Ghana requirements, NIA and contracted providers before production use.

Document control and reading guide

This document converts the client-facing project blueprint into an internal build plan. It preserves the intended operating model while making the boundaries, controls, responsibilities and unknowns explicit.

Marker	Meaning	Treatment
[Baseline]	Requirement or operating assumption already stated in the supplied project blueprint.	Retained unless a later decision supersedes it.
[Agreed decision]	Direction stated in the referenced planning conversation.	Treat as current design direction; validate with the client during Phase 0.
[Technical recommendation]	Stormglide architecture decision proposed to make the solution safe and buildable.	Requires Phase 0 acceptance before implementation.
[Open decision]	A consequential item the client or regulated partner must decide.	Do not infer; record owner, deadline and evidence.

Source reconciliation

Topic	What the baseline says	Normalized technical position
Scope	One connected platform for Susu, microcredit, hire purchase, welfare, branches and about 200 paired field agents.	Retain. Build the common financial core once, then expose it through controlled product modules and channels.
Money movement	The initial system records and tallies cash; it does not move money or require Mobile Money integration.	Retain for initial release. Any later payment collection or payout is a separate regulated integration programme.
Identity	Ghana Card verification is used at registration; KYC is required.	Ghana Card and approved NIA IVSP verification are the primary identity route. Android phone biometrics only unlock the agent app; they do not supply a customer fingerprint to NIA.
NHIS	Not defined as a primary KYC route.	Supporting captured card image and member-entered details only; never accepted as primary KYC or a substitute for Ghana Card verification.
Roadmap count	Executive summary says 4 phases; delivery table lists Phase 0 through Phase 4.	Use Phase 0 (discovery and controls) plus four delivery phases. This is five stages, followed by ongoing support.

[Critical boundary] No client channel, Firebase product, agent device, SMS/USSD callback or portal browser may post ledger entries directly. All financial state changes go through the Financial Core API.

Executive architecture decision

The recommended design is a hybrid Firebase and PostgreSQL architecture on Google Cloud. Firebase is the delivery and trusted-device platform. PostgreSQL is the authoritative financial system of record. Cloud Run hosts the server-side financial and integration services. This maintains fast mobile and web delivery without asking a document database to enforce banking-grade transactions, locking and accounting invariants.

Layer	Authoritative responsibility	Primary technology
Channels	Present workflows and collect input; never decide balances or approvals.	Next.js PWA and public website; native Android app; USSD and SMS adapters
Identity and app trust	Authenticate users, attest apps, register devices and deliver push configuration.	Firebase Authentication, App Check, FCM, Remote Config, Crashlytics, Analytics
Financial Core	Validate commands, create double-entry journal, enforce idempotency, approval and branch rules.	TypeScript services on Cloud Run plus PostgreSQL
Evidence and documents	Store encrypted photographs, agreements and KYC documents with immutable references.	Firebase Storage / Google Cloud Storage with server-only signed access

Layer	Authoritative responsibility	Primary technology
Integration edge	NIA IVSP, USSD, SMS, credit bureau, bank statements, MDM and optional future payments.	Cloud Run adapter services, Pub/Sub and provider-specific queues

1 System context goals and boundaries

[Baseline] The business serves community members through Susu savings, micro credit, hire purchase and welfare. Agents work in pairs, branches receive and pay cash, and management needs same-day visibility and cash controls.

[Agreed decision] The system must have a controlled fallback when biometric and external KYC verification fails; a failed scan must not become either an automatic rejection or an easy staff override.

1.1 Goals

- Trace each collection from member through agent pair, branch handover, branch close and bank reconciliation, with a durable receipt and evidence trail.
- Make the member record, financial position and requests consistent across agent app, member PWA, USSD, SMS, branch portal and reports after confirmed sync.
- Support financial products only through configured business rules, limit approvals and append-only journal entries.
- Operate through intermittent connectivity without double-posting, losing receipts or silently changing the official ledger.
- Create regulatory-ready evidence, auditable decision history and operational controls without pretending the application itself is a licence or compliance certification.

1.2 Explicit non-goals for the first production scope

- No Mobile Money collection, disbursement or wallet custody. USSD and PWA create view or request actions only; cashiers and branches perform the approved cash payout.
- No consumer app may read raw NIA biometrics or use a phone fingerprint sensor as a Ghana Card fingerprint scanner.
- No editable balances, deleted transactions, staff self-approval, direct Firestore ledger writes or client-held provider secrets.
- No automated credit decision that bypasses a configured policy, human review threshold or adverse-decision reason where those are required.

2 Target system and hosting topology

One Google Cloud organization should host separate Firebase projects and GCP projects for development, training/UAT and production. Production services run in a dedicated production project, with least-privilege service accounts and a separately governed billing account.

Zone	Components	Trust boundary and notes
Public edge	Firebase Hosting for Next.js public site and member PWA; CDN; Cloud Armor if the selected hosting topology requires it.	Only static/SSR delivery and BFF calls. No private database access from browser code.
Managed clients	Android agent app, browser PWA, admin/branch portal, USSD and SMS provider callbacks.	Firebase App Check validates app origin where supported. Device binding and role policy remain server-enforced.
Application services	Cloud Run: Financial Core API, Sync API, USSD gateway, KYC gateway, document service, reporting worker, notification dispatcher.	Private service-to-service identity. Egress and provider credentials limited by service.
Financial data plane	Managed PostgreSQL with HA, PITR, encrypted backups, read replica/reporting path where justified.	Only Financial Core and authorised worker service accounts connect. No mobile/browser connection strings.
Async and evidence plane	Pub/Sub, Cloud Tasks, Cloud Scheduler, Firebase Storage / GCS, audit event sink, monitoring logs.	Outbox events are published after database commit. Documents are referenced by immutable IDs and hashes.

2.1 Request and event flow

Member or staff command -> Firebase-authenticated/App Check-attested channel -> Cloud Run API -> policy and idempotency checks -> PostgreSQL transaction and journal -> outbox event -> notification, reporting, fraud or reconciliation worker. The committed journal is the only source for balance projection.

3 Exact recommended stack and responsibility boundary

Capability	Recommended stack	Why this is the chosen boundary
Public site and member PWA	Next.js 15+ / React / TypeScript, Firebase Hosting with SSR through Cloud Run where needed.	Fast public delivery and progressive member experience; works alongside USSD rather than replacing it.
Admin and branch portal	Next.js / TypeScript / React Query / accessible component system on Firebase Hosting.	Role-aware operational interface; browser calls only server APIs.
Agent Android app	Native Android with Kotlin, Jetpack Compose, Room/SQLCipher local store, WorkManager sync, Android Enterprise managed configuration.	Best control over offline data, device policy, background sync, hardware and managed distribution.
Financial services	TypeScript with NestJS or Fastify on Cloud Run; OpenAPI contracts; Cloud Tasks and Pub/Sub.	Typed, independently deployable commands and adapter services with managed scaling.
Financial core database	PostgreSQL 16 managed on Cloud SQL or AlloyDB depending scale and availability requirement.	ACID transactions, constraints, locking, ledger journal, reporting SQL, immutable history and safe reconciliation.
Operational cache	Redis / Memorystore only for ephemeral rate limits, distributed locks and session helpers.	Never store the financial source of truth or approval state only in cache.
Documents	Firebase Storage backed by GCS, CMEK where the selected data classification requires it.	Fine-grained storage policy and signed server-mediated access.
Observability	Cloud Logging/Monitoring/Trace, Error Reporting, Firebase Crashlytics and Analytics, Sentry optional for cross-channel product errors.	Separates server operational evidence from client crash and usage signals.
Infrastructure and delivery	Terraform, GitHub Actions, Artifact Registry, Cloud Build optional, Firebase CLI for Hosting only.	Repeatable reviewable changes and narrow deployments.

3.1 Firebase must handle

- Firebase Authentication identity lifecycle, token issuance and basic claims; App Check; Firebase Hosting; FCM; Crashlytics; Analytics; Remote Config; Storage delivery policy; emulator-backed local development.
- Firestore only for non-financial, transient or replicated read models such as public content drafts, app remote configuration mirrors, in-app announcements and temporary operational presence if a relational record is not required.
- Cloud Functions only for Firebase-native triggers that do not create financial state, such as image post-processing, FCM fan-out helper calls or Analytics-to-notification enrichment. Use Cloud Run for all financial or regulated integrations.

3.2 Firebase must not handle

- The general ledger, member account balance, loan schedule authority, reconciliation match authority, approval chain, cash close, fraud decision evidence or immutable audit log.
- Raw NIA biometric data, card images as public client-accessible objects, provider secrets, private keys, database credentials or logic that relies solely on Firestore security rules for financial correctness.
- Direct client-generated financial writes, scheduled mass financial postings or a substitute for double-entry accounting and database transaction isolation.

4 Channels and product surfaces

4.1 Member customer PWA

[Technical recommendation] The PWA is a richer, optional self-service companion. It must offer the same authoritative view and request behaviours as USSD but is not required for access to core services.

Surface	Initial capabilities	Controls
Member PWA	Profile review; account and transaction read model; statements; request withdrawal, loan, hire purchase or assistance; case status; branch contact; device/session management.	Firebase Auth phone or passkey-assisted sign-in combined with PIN step-up for sensitive actions; server risk checks; masked information; SMS confirmations.
Public website	Brand, locations, services, calculators labelled illustrative, KYC process explanation, interest form, accessibility and privacy content.	No financial account data. Rate-limit forms, CAPTCHA/App Check alternative, consent capture and a route to the correct branch.
Admin/branch portal	Work queues, branch close, reconciliation, approvals, cases, reports, product configuration and audit review.	Workforce MFA, managed browser/device expectation, short sessions, re-authentication for high-risk approval and policy-backed data scoping.
Agent Android	Offline registration intake, collections, route, cash handover, request initiation, supervisor checks and queued evidence capture.	Managed device, device binding, local encryption, biometric local unlock, server-issued session, sync proof and remote revoke.
USSD/SMS	Balance and recent activity views, low-risk requests, status, PIN changes under safeguards and outbound receipts/alerts.	PIN attempt limits, telco/MSISDN risk flags, non-sensitive screen limits, callback signatures, replay protection and SMS delivery state.

4.2 USSD and SMS behaviour

Use a provider-neutral USSDGateway interface with adapters for mNotify, NALO, Arkesel and Africa's Talking. Start provider selection with commercial and coverage validation, not hard-coded provider assumptions. The interface exposes startSession, continueSession and endSession; all session state is short-lived and non-financial. The Financial Core receives a signed, idempotent command from the gateway only after session and PIN policy validation.

Action	USSD/PWA allowed?	Financial result
Check balance/recent activity	Yes	Read-only projection with a "last confirmed" timestamp.
Request withdrawal	Yes	Creates a request and optional reservation under configured policy. No balance debit until approved payout posts.
Request loan/hire purchase/welfare support	Yes	Creates a case/application. No approval, disbursement or value-score override in the channel.
Pay, transfer or disburse money	No in initial scope	Deferred to a separately governed payment programme.
PIN reset	No self-service reset over USSD alone	Agent/branch-assisted recovery with KYC and fraud controls.

5 Identity KYC account recovery and device trust

5.1 Ghana Card and NIA IVSP primary KYC

[Agreed decision] Ghana Card is the primary identity source. NHIS is only supporting captured ID data/photo and cannot approve primary KYC.

Stage	Design	State/result
Capture	Agent captures Ghana Card fields, consent, member photo and required supporting records. The app validates completeness offline but cannot declare KYC complete.	KYC_DRAFT
Online verification	Cloud Run KYC gateway sends only the approved NIA/IVSP request through a contracted provider. Keep provider response reference, method, outcome, timestamp and policy version.	KYC_VERIFIED or KYC_RETRY_REQUIRED

Stage	Design	State/result
Biometric route	Use approved IVSP face/liveness route or a NIA-supported fingerprint reader/MECO device. Phone fingerprint scanner only authenticates the device owner locally.	Method recorded; no raw biometric template stored by application
Controlled exception	Retry conditions first: lighting, capture quality, alternate supported method, IVSP escalation. If still unresolved, create a compliance case.	KYC_EXCEPTION and restricted account
Manual review	Compliance receives evidence, provider case ID and reason. They may request NIA/IVSP escalation or rectification; no generic override button.	RESTRICTED_KYC, then VERIFIED or REJECTED/EXPIRED per policy

Recommended restricted state: the member profile can exist and staff can preserve the evidence, but the product configuration enforces the client-approved post-no-debit / restricted rules until resolution. The exact 90-day rectification treatment and what activity is permitted must be confirmed against the applicable NIA and Bank of Ghana guidance before launch.

5.2 Account recovery

- Member recovery: verify Ghana Card and run a fraud check before changing phone number or resetting PIN. A recent phone change plus withdrawal request must trigger a cooling period or dual review policy.
- Agent recovery: supervisor-assisted device re-enrolment; revoke old device token; verify employee identity, MDM posture and handover of un-synced encrypted queue when recoverable.
- Staff recovery: helpdesk ticket plus workforce MFA recovery and role re-approval. Privileged role recovery requires a separate approver and audit review.
- Never use SMS OTP alone as the sole recovery factor for an account with financial requests. Treat SIM swap and port-out signals as a risk input where available.

5.3 Device binding

The agent app receives a device registration certificate only after Android Enterprise enrolment, managed app configuration and employee binding. The app stores a hardware-backed key where available, attaches attestation evidence and a device ID to each command, and rejects action when the device is revoked, non-compliant or outside the allowed application version grace window. Firebase App Check is an additional signal, not the device-binding system by itself.

6 Authoritative financial core

[Baseline] The supplied blueprint requires a double-entry, append-only ledger, unique transaction IDs, server time as official time and reversals rather than deletions.

6.1 Financial data model

Domain record	Authoritative table group	Core invariants
Identity and organisation	members, member_identifiers, branches, wings, towns, users, agents, pairs, devices, roles	Historic assignment effective dates; no hard-delete for used identities; branch scope is explicit.
Products and contracts	susu_products/accounts, loan_products/contracts, hp_catalog/contracts, welfare_memberships/claims	Versioned terms; contract captures the product rule version accepted at origination.
Commands and evidence	commands, idempotency_keys, documents, cases, approvals, audit_events	Every state change links to authenticated actor, device/channel, correlation ID and evidence.
Accounting	journal_batches, journal_lines, account_balances projection, chart_of_accounts, posting_rules	Each committed batch balances debit equals credit; posted lines immutable; reversal references original batch.
Cash and reconciliation	collections, custody_events, handovers, branch_closes, bank_deposits, reconciliation_matches	Amounts cannot advance to a later custody stage without prior valid state; mismatch remains visible.

6.2 Ledger posting rule

A business command never writes an account balance. It validates policy and creates a journal batch in one PostgreSQL transaction. A balance projection updates from the journal in the same transaction or a transactionally consistent worker. An idempotency key composed from channel, device/client command ID and intent prevents duplicate sync or webhook replay from posting twice. The client-issued UUID is evidence; the server assigns official posting ID and time.

Example business event	Illustrative accounting effect	Control
Cash Susu collection confirmed	Debit agent cash custody; credit member Susu liability.	Receipt only after commit; pair and route evidence attached.
Agent handover accepted	Debit branch cash custody; credit agent cash custody.	Both sides confirm counted amount; variance opens a case.
Cash withdrawal paid	Debit member Susu liability; credit branch cash custody.	Maker-checker request and cashier payout confirmation required.
Loan disbursement paid	Debit loan receivable; credit branch cash custody.	Terms and approval chain frozen before payout.
Correction	Post equal and opposite reversal batch, then corrected new batch if valid.	Original remains immutable; reason and approver required.

6.3 Financial database controls

- Use database constraints, foreign keys, numeric(18,2) currency fields or integer minor-units consistently, posting-period locks and stored procedures/service transaction boundaries for journal posting.
- Use SERIALIZABLE or carefully designed transaction locking for high-risk reserve/payout flows; test contention and deadlock retry logic explicitly.
- Keep separation between application ledger and general-ledger export. The client accountant owns the final chart of accounts mapping and statutory accounting treatment.
- Use append-only database audit logs plus application audit events; database administrators cannot silently alter financial history without generating a security event and recovery evidence.

7 Offline first sync and field cash operations

7.1 Offline sync contract

Requirement	Design decision	Failure handling
Durable local records	Room database encrypted using SQLCipher or Android Keystore-wrapped database key. Persist command queue before UI success.	If storage/encryption fails, block collection and show a clear recoverable error; never keep an in-memory-only receipt.
Exactly-once financial effect	At-least-once delivery with server idempotency. Each command has device UUID, sequence number, intended amount, member and evidence hash.	Duplicate requests return original server result, not a second posting.
Ordering	Per-device monotonic sequence and dependency graph; server does not trust client clock.	Out-of-order commands remain pending or are rejected with explicit reason, not silently reordered.
Conflicts	Financial commands are immutable; profile/product reads use version stamps. Agent cannot merge two financial outcomes locally.	Create a conflict/case or fetch authoritative state; supervisor resolves only through auditable correction.
Receipts	Display provisional local receipt with "pending sync"; issue authoritative SMS/receipt after server commit.	If SMS is delayed, preserve commit receipt and retry notification through outbox.
Remote revoke	Stop new commands when device is revoked after a limited offline grace policy.	Allow secure sync of already-queued signed commands only if policy permits; flag for review.

7.2 Daily cash lifecycle

Collection -> agent pair cash position -> confirmed handover -> branch cashier custody -> branch count and close -> bank deposit -> bank statement match. Each stage uses its own event, counted amount, people, time, evidence and variance. The system must report both member liability and physical custody; they are related but not the same number.

Operational checkpoint	Owner	Required evidence
Collection	Agent pair	Member, amount, product, geo/route signal, time, device, provisional/confirmed receipt state.
Handover	Pair and branch cashier	Expected vs counted amount, both acknowledgements, cash bag/receipt reference, variance reason.
Branch close	Branch manager and cashier	Cash count, float, pending payouts, open variances, signed close.
Deposit and reconciliation	Finance	Bank deposit reference, statement import line, match status, reviewer and unresolved exceptions.

8 Product modules and maker checker

Module	Build behaviour	Key control
Susu	Daily/weekly/monthly packages, multiple accounts, catch-up rules, contribution schedule, reserve/request/payout and statement.	Configured commission and withdrawal rules are versioned. Available balance considers approved reservations.
Loans	Eligibility, credit review, guarantors/lien, approved terms, schedule, collections, PAR 30/60/90 and recovery cases.	Member Value Score is explainable, versioned and advisory/threshold-driven until client approves its policy.
Hire purchase	Catalog, value bands, supplier, deposit, contract, delivery evidence, instalments and recovery workflow.	Supplier payment and member contract are separate approvals; delivery proof required before certain postings.
Welfare	Membership, contributions, claims, evidence, policy-based decision and payout workflow.	Claim conflict checks and defined approver limits; payout remains a cash custody event.
Cases and disputes	Member complaint, receipt dispute, KYC exception, cash variance, fraud alert, data correction and recovery case.	No direct balance edit. Resolution posts a linked adjustment/reversal only after evidence and approval.

8.1 Maker-checker policy

Action	Maker	Checker / rule
Withdrawal request	Agent, member channel or cashier intake	Branch approver within configured amount limit; cashier must be different actor for payout.
Loan / hire purchase approval	Credit officer	Different authorised approver, tiered by amount and policy exception.
Reversal / correction	Operations or finance maker	Independent finance/compliance checker; original transaction must be linked.
Write-off / lien release / welfare payout	Responsible product officer	Independent approver at configured authority level; compliance evidence where required.
Role/limit change	Identity administrator	Separate security or business owner approval; access review retains both records.

9 APIs integrations and asynchronous processing

Use OpenAPI 3.1 contracts for every channel-to-core interface. Each request carries correlation ID, authenticated principal, channel, client command ID and idempotency key. Separate command endpoints from reporting/read endpoints. Publish a versioned domain event after successful commit using a transactional outbox pattern.

Provider / interface	Integration design	Production gate
NIA IVSP / licensed verifier	Cloud Run KYC gateway; provider adapter; encrypted request/response metadata; case correlation.	Contract, lawful purpose/consent language, sandbox or certification, error catalogue and data retention schedule.
USSD gateway	Provider-neutral adapter; signed callbacks; per-session state in Redis with short TTL; core API command calls.	Network coverage, shared/dedicated code, SLA, callback verification and peak-session test.
SMS provider	Outbound notification service; templates, delivery receipts, retry and cost guardrails.	Sender registration, delivery-report webhook, opt-out/legal wording and cost ceiling.
Credit bureau	Batch/file/export adapter first unless a compliant API is contracted; immutable submission records and acknowledgement tracking.	Confirm licence obligation, file format, transmission method, correction process and 72-hour expectation applicability.
Bank statement	Read-only file import initially (CSV/OFX/camt where possible), parser quarantine, matching workbench.	Bank format samples, period close policy, reconciliation owner and exception SLA.
MDM / Android Enterprise	Managed Google Play private app distribution, compliance signal and remote lock/wipe integration.	Enterprise enrollment, company ownership policy, replacement-device procedure.
Future payments	Separate payment orchestration and settlement/reversal service; not connected to ledger directly.	Regulatory/legal review, PSP contract, webhook security, settlement reconciliation, limits and fraud model.

9.1 External failure design

- Treat provider callbacks as untrusted until signature, allow-list, timestamp/replay window and idempotency checks pass.
- Use Cloud Tasks for retryable outbound work, dead-letter queues for exhausted jobs and an operations queue with named owner. Never retry a financial command blindly without idempotency evidence.
- If NIA/USSD/SMS is unavailable, preserve local/queued intake or request state, display the limitation honestly and escalate according to policy. Do not invent a positive verification or delivery result.
- Store provider correlation IDs, request hashes and redacted error classes, not raw secrets or unnecessary biometric payloads.

10 Security privacy and audit

10.1 Security design

Control domain	Required baseline
Authentication	Firebase Authentication with staff MFA; custom claims are coarse routing only. Server evaluates active role, branch, limit and separation-of-duties policy on every command.
Authorization	PostgreSQL policy service and service-layer checks; deny by default; branch/wing scope, product scope and effective dates. Quarterly access recertification.
Secrets	Google Secret Manager; service identity access only; no secrets in Firebase config, app binaries, source control, analytics, tickets or logs. Rotate on personnel/provider change.
Encryption	TLS 1.2+ in transit; database/storage encryption at rest; field-level encryption/tokenisation for highly sensitive identifiers; Android Keystore and encrypted local database.
Network	Cloud SQL private IP or connector; no public database; Cloud Run ingress limited per service; provider egress allow-list where feasible; WAF/rate limits on public endpoints.

Control domain	Required baseline
Audit	Append-only application audit events with actor, before/after logical state, reason, correlation ID, source IP/device, time and linked approval. Export immutable security/audit logs to protected retention storage.
Privacy	Data minimisation, explicit purpose and consent record, access/download/correction workflow, retention jobs, subject-request case handling and staff viewing reason for KYC images.

10.2 Data classification and retention assumptions

Data class	Examples	Proposed retention / handling
Financial and audit	Journal, receipts, approvals, contracts, reconciliation and fraud cases.	At least 5 years after relationship/transaction unless applicable law or regulator requires longer; legal hold overrides deletion.
KYC and identity	Ghana Card fields, verification result/reference, member image and supporting ID documents.	Minimum necessary period under agreed KYC/AML policy; encrypted, tightly scoped viewing and documented deletion review.
NHIS support data	Captured card photo and entered supporting details.	Only if business purpose documented; not used as primary KYC; shorter retention if it has no continuing operational/legal purpose.
Operational telemetry	Crash logs, app version, device health, USSD session diagnostics.	Minimise PII; separate retention by troubleshooting value, typically shorter than financial records.

These are system design assumptions, not a legal retention schedule. The client must adopt an approved data-retention policy and confirm the regulator, AML/FIC, privacy and contractual obligations before live data migration.

11 Backup disaster recovery and service levels

Asset	Backup / recovery design	Target to validate
PostgreSQL financial core	Regional HA, automated daily backups, point-in-time recovery, encrypted off-project backup copy and monthly restore rehearsal.	Proposed RPO 15 minutes; proposed RTO 4 hours for core command service.
Documents	Versioning, retention policy, cross-region replication only after data-residency assessment, restore test against sample case.	Proposed RPO 24 hours for non-financial evidence; tighter where provider evidence requires it.
Configuration and infrastructure	Terraform state protection, versioned deployment manifests, Firestore/config export where used, Secrets inventory not secret value export.	Rebuild a clean environment from code and approved secret rotation process.
Android offline queue	Encrypted device-local queue plus normal sync; no cloud backup of application private financial store.	Data loss risk accepted only for un-synced records after defined device-loss policy; field process mitigates with timely sync.

11.1 Incident model and proposed operating SLOs

Service	Proposed target	Measurement
Financial Core API	99.9% monthly availability excluding approved maintenance; no accepted command without durable commit response.	Synthetic command/read probes, error rate, latency and failed posting metrics.
Agent sync	95% of healthy queued commands confirmed within 15 minutes of usable network return.	Queue age, retry count, device health and sync success dashboard.
SMS receipt dispatch	99% accepted by provider within 5 minutes of posted event; delivery is separately reported.	Outbox lag and provider delivery receipts.

Service	Proposed target	Measurement
High severity incident	Acknowledge in 30 minutes during agreed support window; preserve evidence before remediation.	Incident ticket timeline, audit export and corrective-action review.

12 Observability fraud controls and cases

Signal	Detection logic	Response
Cash variance	Expected collection/handover/close/deposit mismatch above policy threshold.	Block branch close escalation as policy requires; create variance case; notify manager and audit.
Collection anomaly	Drop in pair performance against baseline; repeated missed-member patterns; unusual time/geo distance.	Flag for supervisor field audit; do not automatically accuse or alter balance.
Account takeover	Phone change, SIM risk input, new device or failed PIN sequence followed by withdrawal request.	Cooling period, step-up KYC and independent approval.
Staff misuse	High reversal count, self-approval attempt, unusual after-hours action or permission escalation.	Deny self-approval, create security case and require compliance review.
KYC failure	Repeated no-match, device quality issue or provider outage.	Retry/escalate ladder; restricted KYC state, not bypass.

A case is a first-class record with classification, severity, owner, SLA, evidence, communications, resolution and linked financial/KYC/audit IDs. It is not an informal comment thread. Closing a dispute requires an outcome code and, when money changes, a linked approved journal reversal or adjustment.

13 Environments CI CD and testing

13.1 Environments

Environment	Purpose	Data and controls
Development	Feature work, local emulators and contract testing.	Synthetic data only; disposable Firebase/GCP resources; no provider production credentials.
Training / UAT	Agent and branch rehearsal; acceptance testing and migration dry runs.	Synthetic or irreversibly masked data; managed training devices; isolated project and provider sandbox/shared code.
Production	Live member operations.	Real data only; change control; restricted break-glass access; separate billing, secrets, backups and log retention.

13.2 Delivery pipeline

1. Pull request: lint, type check, unit tests, dependency/security scan, API contract checks, database migration review and infrastructure plan review.
2. Ephemeral or shared test deployment: integration tests with Firebase Emulator Suite, PostgreSQL test database, provider mocks and Android instrumentation tests.
3. UAT promotion: immutable build artifact, signed Android package, release notes, migration rehearsal and acceptance checklist.
4. Production deployment: approval gate; run additive/backwards-compatible migrations first; deploy Cloud Run revision; deploy Firebase Hosting narrowly; verify synthetic flows and a distinctive version marker.
5. Rollback: route traffic to last healthy Cloud Run revision and previous Hosting release where safe. Do not roll back a committed financial migration or journal; use forward correction and an incident-controlled remediation plan.

13.3 Test strategy

Test class	Evidence required before pilot
Financial correctness	Double-entry property tests, invariant tests, idempotency/replay tests, posting-period and reversal tests, concurrency/lock tests.
Offline	Airplane mode, flaky network, killed process, clock shift, duplicate queue, storage pressure, device replacement and two-agent conflict simulation.
Security	Role/branch escape tests, App Check behaviour, device revoke, secrets scan, API abuse/rate limit, webhook forgery and pen test before scale-out.
Integration	Provider sandbox or certified test: NIA error taxonomy, SMS receipts, USSD menu/session expiry, bank import, MDM enrollment and FCM.
Operational acceptance	One full day: collection to handover to close to bank reconciliation, then a dispute/reversal scenario and recovery drill.

14 Migration deployment and rollout

14.1 Migration protocol

1. Inventory paper cards, spreadsheets, branch cash records and existing member identifiers; produce a data-quality report before import.
2. Map and cleanse into staging tables. Resolve duplicate people, missing identifiers and contradictory balances outside the production ledger.
3. Import only signed opening positions with source references, branch approval and a balanced opening journal. Never fabricate detailed historic transactions if only opening balances are reliable.
4. Send opening-balance confirmation through approved member channels and open time-bounded disputes before each branch goes live.
5. Rehearse import, reconciliation and rollback in UAT. Production import is a controlled cutover with a before/after total signed by the branch manager and finance owner.

14.2 Normalized delivery stages

Stage	Timing guide	Deliverable / release gate
Phase 0 - Discovery and controls	Month 1	Signed business rules, licence/category assumptions, data inventory, provider due diligence, threat model, acceptance criteria and pilot readiness plan.
Phase 1 - Core Susu pilot	Months 2-3	Member/KYC intake, offline agent collection, ledger, branch handover/close, SMS receipt, public site v1 and one-branch pilot with about 10 pairs.
Phase 2 - Member access and scale-out	Months 4-5	USSD/PWA view and request flows, withdrawal process, fraud alerts, commissions, branch waves, support operations and 200-agent readiness.
Phase 3 - Credit and hire purchase	Months 6-7	Validated score policy, loans, schedules, bureau reporting/export, catalog/suppliers, delivery proof and portfolio controls.
Phase 4 - Welfare reporting and hardening	Months 8-9	Welfare, regulatory/reporting pack, advanced dashboards, resilience/security review and paper-retirement criteria.
Support and optimisation	Month 10 onward	Health checks, incident review, adoption support, change requests and capacity/cost review.

14.3 Pilot and rollout gates

Gate	Minimum evidence
Pilot entry	Training completed; devices enrolled; KYC and SMS paths tested; ledger/reconciliation rehearsal balances; provider outage playbook; branch owner named.
Pilot exit	At least 2-4 weeks of stable operations; daily cash lifecycle reconciled; no unresolved severity-1 ledger defect; member receipt and support metrics reviewed.
Each branch wave	Opening balances signed; staff trained; device inventory complete; support rota active; paper parallel period defined; exit reconciliation complete.
Credit launch	Client-approved policy and limits; accountant mapping; bureau path certified; PAR reports reconciled; adverse/dispute process active.

15 Bottlenecks failure modes and vendor lock-in

15.1 Likely bottlenecks

Bottleneck	Why it matters	Mitigation / owner
NIA/IVSP approval, contract or uptime	Can delay compliant onboarding or create exception backlog.	Start due diligence in Phase 0; adapter isolation; exception queue and service metrics. Owner: compliance + technical lead.
USSD short-code lead time and network coverage	Member access channel may lag the app rollout.	Apply in Phase 0; support shared-code contingency; contract-test provider adapters. Owner: commercial lead.
Source data quality	Incorrect opening balances damage trust immediately.	Branch-signed migration, sampled source review and member confirmation. Owner: finance + branch management.
Offline operations and phone logistics	A sound app fails if devices are unmanaged, uncharged or untrained.	MDM, spare-device pool, data/power plan, field champions and queue-age monitoring. Owner: operations.
Reconciliation discipline	Technology cannot compensate for missing cash counts/deposits.	Named close owners, variance SLA, management review and no-scale gate. Owner: finance.
Rule churn	Changing products/limits during implementation creates unsafe ambiguity.	Phase 0 rule book and controlled change process. Owner: client sponsor.

15.2 Failure-mode playbooks

Failure	Safe system behaviour	Recovery evidence
Agent app offline for days	Queue immutable commands; show pending status and local cash summary; do not infer central balance changes.	Sync reconciliation report, queue hashes and supervisor review.
Duplicate USSD/webhook request	Reject/return original result by idempotency key; no second posting.	Callback signature, request hash and original posting correlation.
KYC provider unavailable	Keep intake as draft/retry-required; no verified status by proxy.	Provider incident record, retry attempts and compliance queue.
Database/service outage	Fail closed for financial commands; read-only degraded views only if clearly stale-labeled; preserve local queues.	PITR/revision recovery, journal integrity check and incident review.
Wrong amount or cash variance	Open a case; enforce controlled reversal/correction rather than edit.	Original event, counted evidence, approval and linked journal batches.
Lost agent phone	MDM lock/wipe/revoke; prohibit new commands; replace through re-enrolment.	Device revoke event, last sync time, custody review and replacement record.

15.3 Vendor lock-in mitigation

- Keep PostgreSQL schema, migrations, ledger rules and API contracts in Stormglide-controlled source repositories; test regular portable database restore.
- Use provider adapter interfaces for NIA, SMS, USSD, bureau, MDM and future payments. Store business IDs rather than provider-only identifiers where possible.
- Use Firebase for managed app services but keep core domain logic in Cloud Run and PostgreSQL. Export Firestore/Storage/config data on an exercised schedule.
- Avoid writing business decisions into provider workflows, Firebase Rules alone or unversioned admin screens. Product rules belong in versioned database configuration with approval history.

16 Open decisions and compliance assumptions

Decision / assumption	Why it blocks or shapes build	Owner / required evidence
Legal entity and Bank of Ghana licence category	Determines reports, permissible products, supervisory expectations and may affect digital request scope.	Client counsel / regulator confirmation.
NIA/IVSP provider and permitted biometric path	Sets onboarding hardware, consent wording, fallback and commercial cost.	Client/compliance + contracted provider certification.
Restricted KYC policy	Must define what can be opened, credited/debited, notified and for how long when verification fails.	Compliance-approved policy; NIA/BoG guidance validation.
Products and accounting rules	Rates, fees, commissions, catch-up, withdrawal reservations, liens, approvals and write-offs must be deterministic.	Signed Business Rules Specification and accountant chart-of-accounts mapping.
Branch/cash process	Defines custody states, cash limits, close cut-off, deposit timing and variance escalation.	Finance/operations SOP and pilot evidence.
Privacy and retention policy	Controls KYC image, card data, staff access logs and deletion/legal hold rules.	Data Protection Officer/legal review.
Languages and accessibility	Affects USSD labels, training, member support and translations.	Client sponsor and field research.
Provider selections and SLAs	Cost, failover and availability planning depend on real contract terms.	Procurement/commercial comparison and signed contracts.

17 Technical cost and complexity factors for later pricing

No client price is included here. The following factors should feed the later Phase 0 / Phase 1 estimate and the subsequent module estimates. They are separated from pricing so commercial decisions do not distort safe technical scope.

Factor	Why it changes effort or running cost
Number of branches, agents, towns and current members	Sets device enrolment, training, migration volume, operational support and scale testing.
KYC/IVSP provider and biometric hardware	Changes integration certification, per-check fees, field hardware, exception workflow and privacy controls.
Existing data quality	Impacts mapping, reconciliation, duplicate resolution, opening-balance validation and parallel-run duration.
USSD/SMS provider terms	Affects short-code setup, per-session/SMS costs, sandbox availability, delivery reporting and fallback adapters.
Financial product complexity	Multiple products, tiered fees, commissions, liens, guarantees, supplier flows and exceptions expand ledger/posting and test matrix.
Compliance/reporting obligations	Determines audit retention, bureau exports, report templates, approval evidence, security review and legal validation.
Availability and disaster recovery target	HA database topology, backup frequency, cross-region recovery, monitoring and support coverage scale with RPO/RTO.

Factor	Why it changes effort or running cost
Managed device programme	Phones, MDM licences, data bundles, replacement pool, private distribution, power and field support are operating costs.
Migration and rollout model	Per-branch cleansing, training, on-site support, paper parallel-run and opening-balance confirmation drive delivery effort.
Future payment movement	Mobile Money collections/payouts add regulated integrations, settlement/reversal reconciliation, limits, fraud monitoring and provider fees; estimate separately.

18 Risk register

ID	Risk	Likelihood	Impact	Mitigation and trigger
R1	Incorrect opening balances or duplicate members.	High	High	Staged migration, signed reconciliation, member confirmation. Trigger: branch totals fail validation.
R2	Offline sync posts duplicate/lost collections.	Medium	Critical	Idempotency, queue persistence, invariant tests, pilot reconciliation. Trigger: unmatched client/server command.
R3	KYC provider/biometric process fails in the field.	Medium	High	Approved hardware, retry ladder, restricted compliance case. Trigger: no-match/error threshold.
R4	Agent/device compromise or loss.	Medium	High	MDM, encryption, device binding, revoke/recovery SOP. Trigger: device posture or location anomaly.
R5	Cash custody mismatch is hidden or resolved informally.	Medium	Critical	Mandatory close/reconciliation, immutable cases, manager/audit alerts. Trigger: handover/close/deposit variance.
R6	Business rules change after build starts.	High	High	Signed Phase 0 rules and change control. Trigger: unapproved rule request.
R7	USSD or SMS provider outage/delay.	Medium	Medium	Adapters, queue/retry, channel messaging and commercial SLA. Trigger: callback/receipt SLA breach.
R8	Privacy/regulatory requirement misunderstood.	Medium	Critical	Counsel/DPO/compliance review, documented assumptions and pre-production assessment. Trigger: unresolved policy question.
R9	Rollout exceeds operations capacity.	High	High	Wave gates, branch champions, hardware staging and parallel run. Trigger: training/device readiness below threshold.
R10	Firebase or cloud cost grows unexpectedly.	Medium	Medium	Budgets/alerts, data lifecycle, cost dashboard, load tests and monthly review. Trigger: forecast exceeds approved run-rate.

Conclusion and next internal actions

The system is buildable, but it should be built as a controlled financial operating system rather than a collection of apps. The technical centre is the PostgreSQL-backed Financial Core and append-only ledger; Firebase accelerates secure, managed delivery around that centre. Before implementation, Phase 0 must produce an approved business-rules specification, KYC/IVSP provider plan, accounting map, data-migration evidence, device operations plan and pilot acceptance gates.

1. Review and sign the Phase 0 decision register with client sponsor, finance, compliance, operations and legal owners.
2. Run provider due diligence for NIA/IVSP, USSD, SMS, MDM and database hosting, including sandbox/certification and data-processing terms.
3. Create the detailed data model, OpenAPI command contracts, posting-rule catalogue and screen/field workflow prototypes for the Core Susu pilot.
4. Estimate and price only after the open decisions, migration sample and operating model are evidenced.